



Reporte Final VulnerableApp

Nombre: Guillermo Larzen Vazquez Rangel

Grupo: IDGS17

Matricula: 2024171016

Maestro: Gerardo Ramírez Villarreal

Materia: Seguridad en el Desarrollo de Aplicaciones

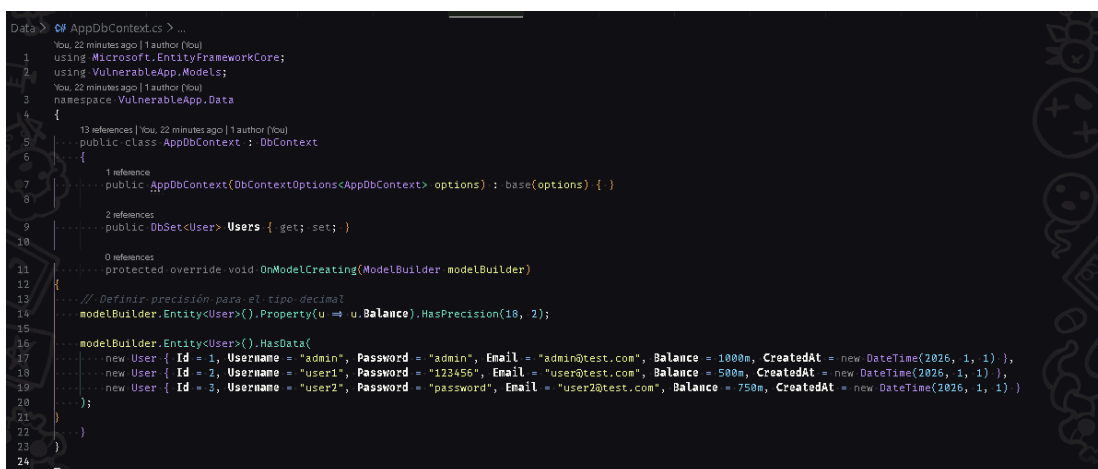
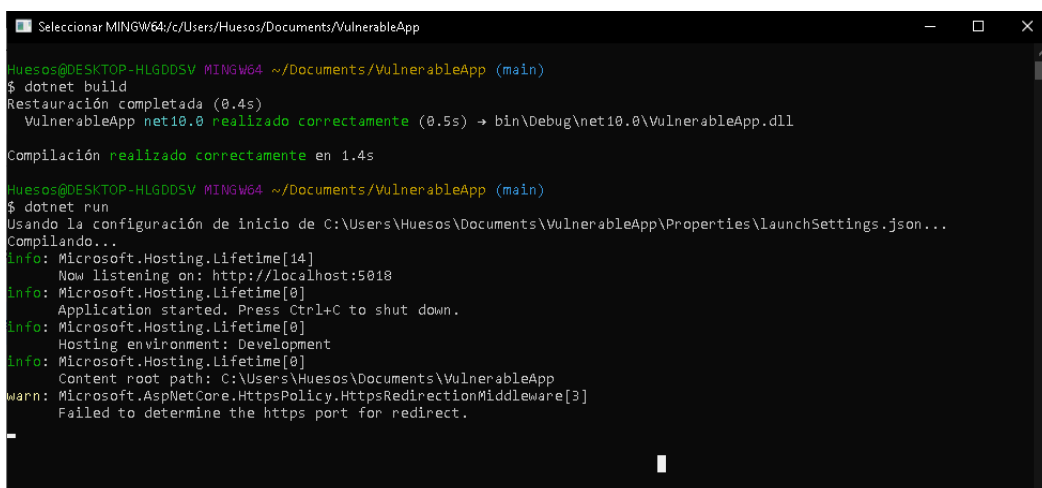
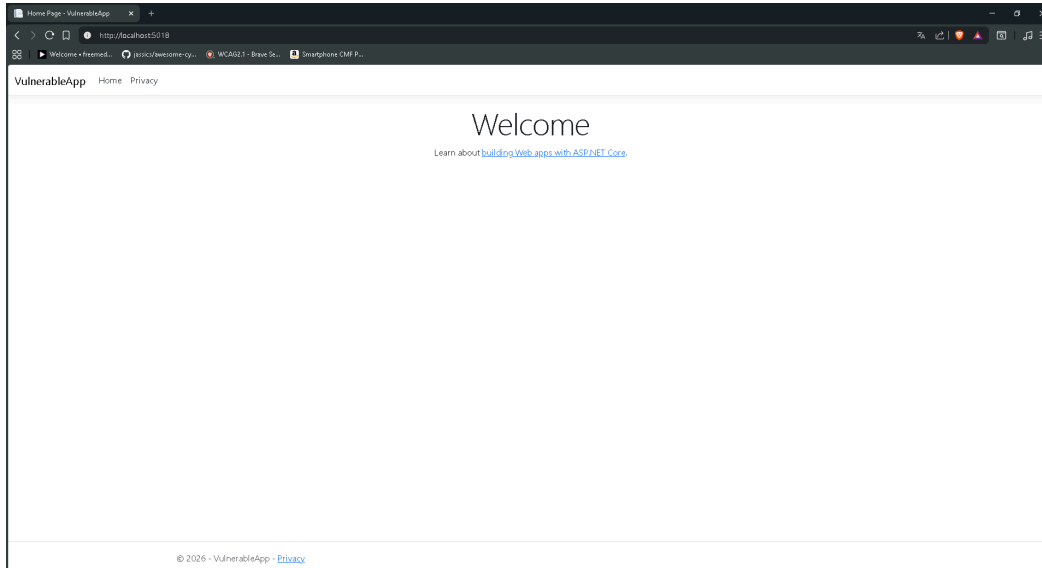
P2A

git clone <https://github.com/GLVR2004/VulnerableApp>

dotnet restore

dotnet ef database update

dotnet run



P2B

La aplicación utiliza concatenación de cadenas para construir consultas SQL en FromSqlRaw. Al ingresar caracteres especiales ('), el atacante puede cerrar la cadena original y añadir condiciones propias (ej. OR 1=1), forzando al sistema a devolver información no autorizada o provocando errores de sintaxis que exponen la estructura de la base de datos.

```
1 using Microsoft.AspNetCore.Mvc;
2 using Microsoft.EntityFrameworkCore;
3 using VulnerableApp.Data;
4 using VulnerableApp.Models;
5
6 namespace VulnerableApp.Controllers
7 {
8     [1 reference | You, 17 hours ago | 1 author (You)]
9     public class SearchController : Controller
10     {
11         [2 references]
12         private readonly ApplicationDbContext _db;
13
14         [0 references]
15         public SearchController(ApplicationDbContext db)
16         {
17             _db = db;
18         }
19
20         [0 references]
21         public IActionResult Index(string search)
22         {
23             if (string.IsNullOrEmpty(search))
24             {
25                 return View(new List<User>());
26             }
27
28             string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'";
29
30             var users = _db.Users.FromSqlRaw(query).ToList();
31
32             return View(users);
33         }
34     }
35 }
```

An unhandled exception occurred while processing the request.

SqlException: Incorrect syntax near '1'.
Unclosed quotation mark after the character string '1'.

Microsoft.Data.SqlClient.SqlConnection.OnError(SqlException exception, bool breakConnection, Action<Action> wrapCloseInAction)

Stack Query Cookies Headers Routing

SqlException: Incorrect syntax near '1'. Unclosed quotation mark after the character string '1'.

Microsoft.Data.SqlClient.SqlConnection.OnError(SqlException exception, bool breakConnection, Action<Action> wrapCloseInAction)
Microsoft.Data.SqlClient.SqlInternalConnection.OnError(SqlException exception, bool breakConnection, Action<Action> wrapCloseInAction)
Microsoft.Data.SqlClient.TdsParser.ThrowExceptionAndWarning(TdsParserStateObject stateObj, SqlCommand command, bool callerHasConnectionLock, bool asyncClose)
Microsoft.Data.SqlClient.TdsParser.TryRun(RunBehavior runBehavior, SqlCommand cmdHandler, SqlDataReader dataStream, BulkCopySimpleResultSet bulkCopyHandler, TdsParserStateObject stateObj, out bool dataReady)
Microsoft.Data.SqlClient.SqlDataReader.get_MetaData()
Microsoft.Data.SqlClient.SqlCommand.FinishExecuteReader(SqlDataReader ds, RunBehavior runBehavior, string resetOptionsString, bool internal, bool forDescribeParameterEncryption, bool shouldCacheorAlwaysEncrypted)
Microsoft.Data.SqlClient.SqlCommand.RunExecuteReaderTds(CommandBehavior cmdBehavior, RunBehavior runBehavior, bool returnStream, bool isAsync, int timeout, out Task task, bool asyncWrite, bool inRetry, SqlDataReader ds, bool describeParameterEncryptionRequest)
Microsoft.Data.SqlClient.SqlCommand.RunExecuteReader(CommandBehavior cmdBehavior, RunBehavior runBehavior, bool returnStream, TaskCompletionSource<object> completion, int timeout, out Task task, out bool usedCache, bool asyncWrite, bool inRetry, string method)
Microsoft.Data.SqlClient.SqlCommand.RunExecuteReader(CommandBehavior cmdBehavior, RunBehavior runBehavior, bool returnStream, string method)
Microsoft.Data.SqlClient.SqlCommand.ExecuteReader(CommandBehavior behavior)
Microsoft.Data.SqlClient.SqlCommand.ExecuteReader(DbDataReader(CommandBehavior behavior))
Microsoft.EntityFrameworkCore.Storage.RelationalCommand.ExecuteReader(RelationalCommandParameterObject parameterObject)
Microsoft.EntityFrameworkCore.Query.Internal.FromSqlQueryingEnumerable<T>.Enumerator.InitializeReader(Enumerator enumerator)
Microsoft.EntityFrameworkCore.Query.Internal.FromSqlQueryingEnumerable<T>.Enumerator.MoveNext()<b_21_0(DbContext _ DbContext, Enumerator enumerator)>
Microsoft.EntityFrameworkCore.Server.Storage.Internal.SqlServerExecutionStrategy.Execute<TState, TResult>(TState state, Func<DbContext, TState, TResult> operation, Func<DbContext, TState, ExecutionResult<TResult>> verifySucceeded)
Microsoft.EntityFrameworkCore.Query.Internal.FromSqlQueryingEnumerable<T>.Enumerator.MoveNext()
System.Collections.Generic.List<T>.ctor(Enumerable<T> collection)
System.Linq.Enumerable.ToList<TSource>(IEnumerable<TSource> source)
VulnerableApp.Controllers.SearchController.Index(string search) in SearchController.cs
26. var users = _db.Users.FromSqlRaw(query).ToList();
lambda_method18(Closure, object, object[])
Microsoft.AspNetCore.Mvc.Infrastructure.ActionMethodExecutor+SyncActionResultExecutor.Execute(ActionContext actionContext, IActionResultTypeMapper mapper, ObjectMethodExecutor executor, object[] arguments)
Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.InvokeActionMethodAsync()
Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.Next(ref State next, ref Scope scope, ref object state, ref bool isCompleted)
Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.InvokeNextActionFilterAsync()
Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.InvokeNextActionFilterAsync()

VulnerableApp Home Privacy

Búsqueda de Usuarios

Nombre de usuario...

Usuario	Email	Balance
admin	admin@test.com	\$1000.00

P2C

VulnerableApp

Home

Privacy

Login

Usuario: admin

Password:

Entrar

VulnerableApp

Home

Privacy

Bienvenido al Dashboard, admin

Cerrar sesión

VulnerableApp

Home

Privacy

Bienvenido al Dashboard, user1

Cerrar sesión

VulnerableApp

Home

Privacy

Login

Usuario:

Password:

Entrar

Credenciales incorrectas